Nmap Student Handbook

What is Nmap?

Nmap (Network Mapper) is an open-source tool for network discovery and security auditing. It finds hosts, open ports, identifies services and versions, and runs scriptable checks (NSE) that extend its capabilities (vulnerability checks, credential testing, traceroute, etc.). It's the first step in most penetration tests.

Prerequisites

- Kali Linux (or any Linux with Nmap installed)
- Target VM (Metasploitable recommended) on same isolated network
- Basic familiarity with Linux terminals and IP addressing
- Optional: tcpdump / Wireshark for deeper packet-level analysis

---

Nmap Scanning Workflow

1. Host discovery (is target up?)
2. Port scan (which ports are open?)
3. Service & version detection (what is running?)
4. Targeted script/enum scans (NSE, dirb, enum4linux, etc.)
5. Save output and map to exploits (searchsploit / msfconsole)

Essential Nmap Commands

> Replace <TARGET> and <YOUR_IP> with your lab IPs.
>
> These are the most frequently used and **industry-relevant** commands for reconnaissance and vulnerability scanning in real penetration testing.

---

1. Full TCP SYN Scan (All Ports)

```
# Scans all 65,535 TCP ports, detects services and versions
nmap -sS -sV -p- -Pn <TARGET>
```

Explanation:

- `sS` → Stealth TCP SYN scan (does not complete handshake).

- `sV` → Detects running service name & version.
- `p-` → Scans all ports (1–65535).
- `Pn` → Treats host as alive (skips ping); useful when ICMP is blocked.

---

2. Default Script Scan + Version Detection

```
# Uses safe built-in scripts and detects versions for common services
nmap -sC -sV <TARGET>
```

Explanation:

- `sC` → Runs Nmap's default NSE (Nmap Scripting Engine) scripts (safe info-gathering checks).
- `sV` → Service/version detection.

  Use this to quickly discover common misconfigurations or default settings.

---

3. Scan Specific Ports

```
# Scan only chosen ports
nmap -sS -sV -p21,22,80,443,445 <TARGET>
```

Explanation:

- `p` specifies particular ports (comma-separated).

  Use this when you already know key services to check.

---

4. Scan the Top 1000 Common Ports

```
# Fast scan for top 1000 most-used ports (default behavior)
nmap -sS -sV <TARGET>
```

Explanation:

If you don't specify `-p`, Nmap automatically scans the 1000 most common ports based on global frequency data.

Fast and ideal for quick reconnaissance.

---

5. Run Vulnerability Scripts

```
# Run all vulnerability-related scripts on detected services
nmap --script vuln <TARGET>
```

Explanation:

- `-script vuln` runs all scripts in the “vuln” category.

  Quickly checks for known CVEs, weak configurations, and outdated software.

---

6. Example — Vulnerability Scan on SMB & HTTP

```
# Check SMB vulnerabilities
nmap --script smb-vuln* -p139,445 <TARGET>

# Check web vulnerabilities
nmap --script http-enum,http-vuln* -p80,8080 <TARGET>
```

Explanation:

Use targeted scripts against known open services for focused results.

---

7. FIN/XMAS (Stealth) Scan

```
# FIN scan (for stealthy testing of firewall behavior)
nmap -sF <TARGET>

# XMAS scan (sets multiple TCP flags for evasion)
nmap -sX <TARGET>
```

Explanation:

- Used for **stealth & evasion demonstrations** in labs.
- Bypasses simple firewalls that rely only on SYN detection.

---

8. Timing Templates

```
# Control speed and stealthiness
nmap -T1 <TARGET>   # Sneaky (very slow, stealthy)
nmap -T2 <TARGET>   # Polite (reduced speed)
nmap -T3 <TARGET>   # Normal (default)
nmap -T4 <TARGET>   # Aggressive (fast, typical for labs)
nmap -T5 <TARGET>   # Insane (very fast, noisy)
```

Explanation:

- The higher the `T` level, the faster (and noisier) the scan.
- Use `T3` for normal operations; `T4` for lab demos.

  Avoid `-T5` on real networks — it may flood the target.

---

9. Intense (Aggressive) Scan

```
# One command to detect OS, version, scripts, and traceroute
nmap -A <TARGET>
```

Explanation:

- `A` = OS detection + version detection + script scan + traceroute.

  Ideal for detailed reconnaissance and teaching multiple features together.

---

10. Output for Reporting

```
# Save results in multiple formats
nmap -sS -sV -oN nmap.txt -oX nmap.xml <TARGET>
```

Explanation:

- `oN` → normal human-readable output.
- `oX` → XML format for report tools or import into Metasploit.

  Keep all commands & output saved for professional documentation.

How to Read & Interpret Nmap Output

Example snippet:

```
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 2.3.4
22/tcp   open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (protocol 2.0)
80/tcp   open  http    Apache httpd 2.2.8
```

- **PORT**: Port number/protocol (e.g., `80/tcp`)
- **STATE**: `open`, `closed`, `filtered`; `open` means service listening.
- **SERVICE**: Nmap's guess of service by port and banner.
- **VERSION**: Detected software + version (used to map to CVEs/exploits).

Actionable mapping:

- `vsftpd 2.3.4` → candidate exploit `vsftpd_234_backdoor` (classic lab example).
- `OpenSSH 7.x` → check for user brute-force, weak keys, or known CVEs (map via searchsploit/CVE lookup).
- `Apache 2.2.8` → check for outdated modules, CVEs, and directory enumeration.

Nmap NSE (Scripting Engine) — Practical Use Cases

NSE scripts enable checks like authentication testing, default creds, vuln detection, brute force, and info gathering.

Common script categories:

- `auth` — authentication tests
- `vuln` — vulnerability checks (e.g., `smb-vuln-ms17-010`)
- `discovery` — OS/uptime info, traceroute
- `brute` — password guessing scripts
- `exploit` — automated exploits

Examples:

```
# SMB vulnerability check (MS17-010 / EternalBlue)
nmap --script smb-vuln-ms17-010 -p445 <TARGET>

# HTTP enum / check common files
nmap --script http-enum -p80,8080 <TARGET>

# Run multiple scripts (comma separated)
nmap --script vuln,http-enum -p80,445 <TARGET>
```

Teaching tip: Start with `-sC` (default scripts) to show quick extra intelligence, then run targeted `--script` scans for focus.

Hands-On Lab Exercises

Lab 1 - Basic Recon

Goal: Use Nmap to discover running services and identify one likely exploitable service.

Steps:

1. Ensure Kali and target VMs are running and on the same isolated network.
2. Run a full TCP SYN scan:

   ```
   nmap -sS -sV -p- -T4 -Pn 192.168.56.101 -oN lab1_fullscan.txt
   ```

3. Run default scripts against discovered ports:

   ```
   nmap -sC -sV -p21,22,80,139,445,8080 192.168.56.101 -oN lab1_scripts.txt
   ```

4. Choose one service (service + version) that looks vulnerable and note the exact output lines as evidence.

Lab 2 - Targeted NSE Enumeration

Goal: Use NSE scripts to check for common vulnerabilities and credential issues.

Steps:

1. Pick a port/service from Lab 1 (e.g., SMB on 445).
2. Run vulnerability script(s):

```
nmap --script smb-vuln* -p445 192.168.56.101 -oN lab2_smb.txt
```

3. If HTTP is present, run:

```
nmap --script http-enum,http-vuln* -p80,8080 192.168.56.101 -oN lab2_http.txt
```

4. Summarize any positive findings and map to potential next steps (exploit with Metasploit, credential testing, manual verification).